Oversight

What needs a decision today, across every claim PoliBridge holds.

SYNTHETIC · REPLAY 15 MAR 2017 14:20

Board summary

HIGH IMPACT CVE-2017-5638 · Apache Struts 2 remote code execution — obligation cannot close: **2 assets remain Cannot Determine**, 1 remediation is past its deadline. Open advisory →

Overdue tasks	Cannot Determine	Active risk acceptances	Expired evidence	Lapsed monitoring	Canary pass rate
3	7	4	5	1	11/12
2 High impact	assets blocking closure	1 expires in 6 days	reverted this week	ACIS traffic inspection	ACIS routing failed

Overdue and escalated

All tasks

Task	Owner	Late by	Escalated to
Investigate Struts on ACIS TSK-0412 · High	D. Whitfield rerouted · BU head	5h 08m	Risk owner, board report
Renew inspection certificate TSK-0419 · High · SSLV-02	K. Osei	14h 20m	Owner's manager
Refresh SBOM, batch reporting TSK-0398 · Medium	S. Ramírez	2d 05h	Owner's manager

Claims that lapsed this week

All claims

14 Mar	**“ACIS outbound traffic is inspected”**	Certificate on SSLV-02 expired · 3 dependent decisions reopened
15 Mar	**“ACIS does not use Struts”**	Evidence rejected — scan scope missed the component · reverted to Cannot Determine
02 Feb	**“R. Okafor owns ACIS”**	Leaver event invalidated attestation · ownership finding DQF-0088 open

SELF-TEST · CNY-0311 · ACIS

Routing canary failed: the ACIS owner record points to a distribution list

A test advisory could not reach a named person. Reported separately from operational metrics and assigned to the business-unit head.

View canary run

HIGH IMPACT · Security advisory · fast path

CVE-2017-5638 · Apache Struts 2 remote code execution

Source & version history

Ingested automatically from US-CERT and NVD on 8 Mar 2017, 09:12 and matched against every asset's component records. Advisories bypass the Compliance/Legal gate.

Structured advisory

Product	`apache:struts2-core`
Affected	`2.3.5 – 2.3.31, 2.5 – 2.5.10`
Fixed in	`2.3.32, 2.5.10.1`
Severity	Critical · CVSS 10.0 · exploited in the wild

Why High impact

Appendix B

- ✓ Critical, exploitable vulnerability
- ✓ Internet-facing assets in scope
- ✓ Personal data classified Confidential

Acknowledge	Interim control	Remediate
24h	48h	7 days

Applicability across the estate

Missing or stale data becomes Cannot Determine — never Does Not Apply.

2 Applies · 2 Cannot Determine · 2 Does Not Apply

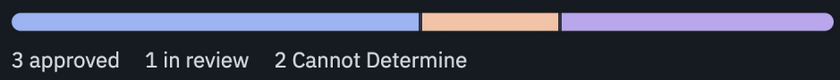
Asset	Component record	State	Basis	Task
ACIS · consumer dispute portal Internet-facing · personal data	None on record	? Cannot Determine	No component data. “Does Not Apply” claim rejected 15 Mar — scan scope did not cover the component.	TSK-0412 Investigation · overdue
Credit File API Internet-facing · personal data	`struts2-core 2.3.30` `SBOM · CycloneDX · 2 Mar`	● Applies	Version in affected range.	**TSK-0413** Remediated · verified 11 Mar
Member portal Internet-facing · personal data	`struts2-core 2.5.8` `SCA scan · 6 Mar`	● Applies	Version in affected range.	**TSK-0414** Fixed · awaiting independent review
Batch reporting server Internal	`SBOM · Jan 2016` `stale · over 12 months`	? Cannot Determine	Component data too old to rely on.	**TSK-0415** Investigation · acknowledged
HR payroll · vendor SaaS Internet-facing · third party	`Vendor SBOM · CycloneDX` `1 Mar`	– Does Not Apply	Component verified absent · reviewed by A. Mensah.	No task
Internal wiki Internal	`Authenticated inventory` `7 Mar`	– Does Not Apply	Component verified absent · reviewed by A. Mensah.	No task

Anyone may move an asset to a more cautious state with a reason. Moving it to Does Not Apply needs component-scoped evidence and an independent reviewer.

OBLIGATION OBL-0308 · CLOSURE GATE

3 of 6 assets have an approved disposition

Closes only when every affected asset is remediated or under approved risk acceptance, and none remains Cannot Determine.



HIGH IMPACT · ? Investigation · ACIS is Cannot Determine · OVERDUE

Establish whether ACIS runs an affected Struts version

ACIS has no component record, so PoliBridge cannot rule it in or out. Supply component-scoped evidence, or remediate, or request time-limited risk acceptance.

Acknowledgement · 24h
Acknowledged
8 Mar 16:05 · after 6h 53m

Interim control · 48h
Reopened
relied on MC-019, lapsed 14 Mar

Disposition · 7 days
−5h 08m
due 15 Mar 09:12 · not reset

Routing and escalation

8 Mar 09:12	**Routed to R. Okafor — owner record invalid**	Directory shows a leaver event on 2 Feb. The task was never sent to a mailbox or list.
8 Mar 09:12	**Rerouted to D. Whitfield, business-unit head**	Original deadline kept. Ownership-correction finding DQF-0088 raised.
8 Mar 16:05	**Acknowledged by D. Whitfield**	Manager escalation at 24h and CISO escalation at 48h were not needed.
9 Mar 17:40	**Interim compensating control approved**	Web-application firewall rule on ACIS, with detection relying on traffic inspection (MC-019).
14 Mar 23:59	**Interim control reopened**	MC-019 lapsed with the SSLV-02 certificate.
15 Mar 09:12	**Deadline missed — escalated**	To P. Hargreave (accountable risk owner) and senior management. Added to the next board risk report.
15 Mar 12:30	**“Does Not Apply” evidence rejected**	Scan scope did not cover the component. See review

People

Owner	D. Whitfield Head, Consumer Services
Manager	L. Varga
Risk owner	P. Hargreave
Reviewer	A. Mensah must differ from submitter

To close this task

A direct version check or authenticated scan whose recorded scope covers `struts2-core` on ACIS — or approved, time-limited risk acceptance.

Submit evidence

Request risk acceptance

Reject — not my system

Rejecting reroutes the task immediately and raises an ownership finding. The deadline keeps running.

CLAIM CLM-2291 · APPLICABILITY

“ACIS does not use Struts”

Submitted by J. Park, 15 Mar 11:02. A negative claim is held to the same standard as a fix: the evidence must have examined the component.

Scope check failed — evidence cannot support this claim

ACIS reverts to Cannot Determine and TSK-0412 stays open. PoliBridge flags what the evidence lacks; it never infers safety from an uploaded report.

Claim versus evidence

Rules E1–E3

Check	Claim requires	Evidence recorded	Result
Asset	ACIS-PRD-01	ACIS-PRD-01	✓ Pass
Component scope	struts2-core, any path under /opt/acis/**	/opt/acis/ · depth 1	✕ Fail
Method	Authenticated scan or direct version check (critical item)	Unauthenticated external scan	✕ Fail
Timestamp	Within scan validity · 7 days	15 Mar 10:48	✓ Pass
Independence	Reviewer differs from submitter	J. Park → A. Mensah	✓ Pass

What the scan actually examined

/opt/acis/ scanned

```
└ webapps/
  └ dispute/
    └ WEB-INF/lib/
      └ struts2-core-*.jar
```

Not examined — where the component lives

A clean result here says nothing about Struts. Running a scan is not the same as checking the component.

Reviewer decision

Reason recorded with the decision

Scan scope ends at /opt/acis/ depth 1 and is unauthenticated. Provide a direct version check of struts2-core on ACIS-PRD-01, or an authenticated scan scoped to /opt/acis/**.

Confirm rejection | Request specific evidence

Approve is unavailable while any check fails.

Monitoring claim · ? Lapsed → Cannot Determine

“ACIS outbound traffic is inspected”

This claim was only as good as the certificate on the inspection device. When the certificate expired, so did the claim.

Evidence life

Expiry tied to the SSLV-02 certificate

16 Sep 2016 · accepted — 15 Feb · reminders to owner — **14 Mar 23:59 · lapsed**

What the lapse reopened

Rule F2 · each flagged to its owner

DEPENDS ON
TLS certificate · SSLV-02
Expired 14 Mar 23:59

→

THIS CLAIM · MC-019
ACIS traffic is inspected
Now Cannot Determine

→

DEPENDED ON BY · 3 REOPENED

- **Interim control on TSK-0412** — D. Whitfield
- **Risk acceptance RA-0103 · legacy TLS on ACIS** — P. Hargreave
- **Board report item Q1-07 · monitoring coverage** — CISO

Claim record

Asset · component	ACIS-PRD-01 · egress via SSLV-02
Evidence scope	Decryption policy for ACIS egress
Method	Certificate and configuration check
Evidence time	16 Sep 2016 10:20
Submitter	K. Osei
Reviewer	T. Brandt
Expiry	14 Mar 2017 23:59

History

16 Sep 2016	Accepted. Expiry set from the certificate.
15 Feb · 7 Mar	Renewal reminders to K. Osei. No new evidence.
14 Mar 23:59	**Lapsed. Reverted to Cannot Determine.**
15 Mar 00:00	3 decisions reopened. TSK-0419 “Renew inspection certificate” created, High.

Canary self-tests

Synthetic advisories, marked as tests, check that routing reaches a named person and escalation fires on time. They test the process, not whether a fix worked.

This quarter
11/12 passed

CNY-0311 · ACIS · 11 MAR 03:00

Run triggered by an ownership change on ACIS

FAILED AT ROUTING

1 · PASS	2 · PASS	3 · FAIL	4 · NOT RUN	5 · PASS
Test advisory injected	**Matched to ACIS**	**Reached a named owner**	**Acknowledged in time**	**Fallback routing**
PB-CANARY-0311, labelled TEST.	Via its test component record.	Owner record resolves to `acis-ops`, a distribution list — not a directory identity.	Blocked by step 3.	Reached D. Whitfield, business-unit head.

Finding **DQF-0091** assigned to D. Whitfield: replace the list with a named owner. Reported separately from operational metrics.

Open finding

Recent runs

Scheduled, and after changes to owners, assets or routing rules

Run	Asset	Trigger	Named owner	Acknowledged	Result
CNY-0311	ACIS	Ownership change	✕ Distribution list	—	Failed
CNY-0309	Credit File API	Scheduled	✓ M. Adeyemi	2h 10m	Passed
CNY-0306	Member portal	Routing rule change	✓ H. Kowalski	5h 42m	Passed
CNY-0228	Batch reporting server	Scheduled	✓ S. Ramírez	Not acknowledged · escalated at 48h on time	Passed

Runs are unannounced. Internal Audit runs its own seeded-fault tests independently of these canaries.